

Contents:

1. Users of the system
2. Interface Layout
3. Access and Security of the system
4. System error handling

1. Users of the system

Admin user:

- Admin user will be created in the development stage of the web application with credentials assigned to myself.
- This will allow me to create different users, products or stores for the testing of the application.

Buyers:

- Buyers will be able to register from the registration screen and will be able to view and search for all products from their homepage.
- Will be able to add items to their cart when they are viewing product details. They will also be able to check out their cart which will send an email invoice to the buyer, using the email they registered for the site with.
- Buyers will be able to leave reviews on any product within the site. A review will be marked with a verified if the buyer has a history of buying the product and an unverified tag if the buyer has never purchased that specific product before.
- Buyers will be able to view their own profile and change their email, username or password from that page, as well as remove their account.
- At the login page there will be an option to recover your password if you forgot it.

Vendors:

- Vendors will be able to register themselves from the registration page and will be able to do this by selecting the vendor radio button on registration.
- Vendors will be able to create stores that they can then list products for sale within each of those stores. Vendors will be able to perform CRUD operations on their stores (create, view, edit or delete) from within the store page.
- Vendors will be allowed to perform CRUD operations on their products within their individual stores from the product detail page. They will be able to add new products, view, edit or delete existing products that belong to one of their stores.
- Vendors will be able to view their profile page and have reign to edit their profile from that page.
- Vendors will be allowed to recover their password from the login page if they forgot it.

2. Interface Layout

The interface layout will be different for buyers and vendors because they will require different permissions as well as have different interactions with the web application based on their role. There will be a landing page, visible to both roles when visiting the page initially, that will enable the user to either login or register as a vendor or a buyer. After the user has made a successful login the interface will change depending on their role.

Landing page interface:

- This is login / register page that will be available to all users regardless of roles.
- This page will include a forgot password link that will email a password reset link to the user that will enable them to change their password. This will then redirect the user back to the login screen where the user will be able to use their updated credentials to log back into the site where they will be redirected to the buyer or user homepage.
- If the user selects the registration option they will be taken to a form where they will be able to enter a unique username that will be used to identify the user, an email address, a radio button to select their role (vendor or buyer), a password field and a confirm password field. Once they complete the registration form they will be redirected to the login page that will then take them to their respective homepage based on role.

Base interface:

- Once a vendor or buyer completes a successful login attempt they will be presented with an individual homepage based on their role, however, the homepage for both roles will extend the base template which will include 3 options, a return to homepage, a logout and a view profile option.
- The logout option will return the user to the landing page that will allow the user to login or register a different user, or recover password.
- The homepage button will allow the user to return to their individualised homepage based on roles.
- The view profile option will take the user to their profile page that will allow the user to edit their details.
- They will not be able to change roles from this page as that will require a user to create a separate vendors or buyers profile.

Buyers interface:

- Will always extend the base layout, regardless of the page the buyer visits.
- A buyer homepage will be displayed following a correct login attempt for a user with the role of buyer selected. This homepage will include a list of all the products, as well as the price of the product that are available on the e-commerce site.
- When a user selects a product they will be taken to the product detail page where they can view the cost of the product, its description and the reviews of the product that other buyers have left. The user will be able to leave a review of the product and that review will have an indicator (verified or unverified) based on whether or not that buyer that left the review had purchased that product before or not. Buyers will have an option to add any item to their cart from this page by clicking the add to cart button above the reviews section of each product.
- The buyers will have the option of selecting their cart that they can view from any page they visit once logged in. When the user selects their cart, it will display an empty note if there are no products in the cart, otherwise it will display the product, the quantity, the individual cost, the cost multiplied by the quantity and the total value of all items in the cart. The user will be able to edit or delete completely any number of specific items in their cart from the cart view. The user will be allowed to checkout the cart if they wish.
- When the user checks out their cart, an invoice will be generated and sent to the user, at the email they used to sign up as a buyer, with the list of items and the total cost of the items. The user will then be displayed a relevant message based on whether the checkout was a success. After this the user

can the return to the homepage and continue browsing, or begin adding new items to their, now, empty cart.

Vendors interface:

- Will extend the base layout as discussed above regardless of the page the vendor will visit.
- The homepage of the vendor will show the list of all the vendors stores that they have created within the web application as well as a link to create a new store. If the vendor has not yet created any stores they will only be presented with the option of creating a new store.
- When a vendor chooses to create a new store they will be taken to a form they can complete with the stores name and its description of the store, and a create button. Once they fill in the details and use the create button, they will be taken to that store page where they will be able to add products to the store.
- If the user decides to create a new product they will be taken a page where they will be presented with a form to complete the product details. These details will include a title, description, price and available stock. There will be a button at the bottom of the form to submit the product for creation. Once the product has been created it will be considered 'listed' and they will be taken to the product detail page.
- Once a vendor has created a store and a product within the store they will be afforded different options when entering a store or a product within a store:
 - When a vendor accesses one of their stores from the home page they will be presented with store editing options like update store information and delete the store.
 - Store editing options will take the user to a form that will enable them to edit the title and description of the store and to save it. The user will then be returned to the store detail page.
 - If the vendor decides to delete there store, there will be a confirmation page with a button to state they confirm they want to perform the delete and the store will be deleted, along with all the listed products. The vendor will then be returned to the store list page.
 - The user will also be presented with a list of products within the store that they can view by clicking on the product. Inside each product they will be presented with options to edit or delete the product.
 - If the vendor chooses to edit a product they will be presented with a form to change the title, description, price or stock. When editing is completed they will be returned to the product detail page.
 - If a vendor chooses to delete a product they will be taken to a confirmation page that will then give the vendor the option of confirming or returning to the product detail page. If the user confirms the product will be deleted and they will be returned to the store that originally contained the now deleted product.

3. Access and Security of the system

Access:

- Access to the site will be controlled by the registration and login pages, together with the database that will store the relevant access data (username, email, password, role).
- In order for a vendor or buyer to have access to the site as a whole they will need to first register an account as either a vendor or a buyer.
- Access between roles will be controlled internally by assigning roles to vendors and buyers. Vendors cannot access features that require a buyer role. This will include all of the cart functionality (building a cart, editing a cart, checking out the cart and receiving an invoice for the items that were checked out).
- Buyers will not be able to access vendor features such as editing or deleting products or stores, as this will require the vendor role to be able to view it.
- If a user forgets their password a forgot password link will provide access but will require a valid email already registered with the e-commerce application.
- Session data is stored securely on the server side and can be configured to use secure HttpOnly cookies that are only sent over HTTPS and cannot be accessed by client side JavaScript.

Security:

- Securing of passwords will be done primarily through Django as they provide hashing of passwords within the framework itself and therefore no passwords will be stored within the database itself, rather a hash of the password. This creates a good level of security to the user as not even the developers side of the site will have access to users accounts.
- There will be an admin user that will have general control over the users and accounts within the site and will be confined to a single user and the lead developer.
- With password reset or recovery it will be done by email which only the user will have access to their personal email address that they have inserted as part of the registration purpose so that will be secured by the user and only accessed by the user.
- Django provides strong authentication and authorization framework that will handle user accounts, sessions and permissions that will control access to different parts of the site based on role.
- Django provides SQL Injection protection by using an Object Relational Mapper that will construct database queries using parametrization, separating SQL code from user provided data.
- Django uses host header validation that will validate the HTTP Host headers which will protect against cache poisoning and other issues from fake host values.

4. System error handling

Development Environment:

- When DEBUG is set to True in the development phase Django provides comprehensive, detailed error messages that assist with error handling and debugging of code. These error messages will include the error type and message, a Python traceback showing the user which line of code was the erroneous one and detail about the HTTP request and local variables at the time of error.
- It is important to not use this mode in production as it can show important or sensitive information to potentially malicious users.

Production Environment:

- In production DEBUG should be set to False and the error system moves to a more robust error handling method that will be displayed via HTTP error codes:
 - Generic errors will be handled with Internal Server Error (500) codes if the error is not handled in the code itself.
 - For client errors there can be individualised returns for specific errors like a '404 Page Not Found' error if they attempt to access a page that no longer exists. Pages can also be generated for specific errors (e.g. '404.html').
 - Email notifications can be set up to email the users in the admin list for any exceptions that are not yet handled with the full traceback so that those errors can be managed quickly.
 - Django makes use of a built in logging module that can be set up and configured to log errors to a file or the console, depending on the developers needs. These logs can then be reviewed to locate errors.
 - Django can apply a sensitive variables filter to certain variables so that they do not appear in logs or error reports.

Customization and advanced handling:

- Internal error handling can be done using coding techniques such as try, except blocks that will catch certain errors if they occur and then respond with the correct HTTP status code response or user message.
- User input can be validated or sanitized so as to maintain data integrity.